SENTEZ · ARMA MANTAR BARİYER · KİMYA TESİSİ GİRİŞİ

SWOT Analizi

Çıktı: TOWS + Yol Haritası

Ad Soyad Mehmet Onur Boyraz · 245541023 | Grup | Tarih 20.10.2026

Kavram — SWOT bir karar aracıdır: iç faktörler (S, W) sistemin, dış faktörler (O, T) çevrenin. Maddeler önem sırasındadır; gri etiket kaynak föyü, G üretici sitesini, V senaryo varsayımını gösterir.

HEDEF
Girişi 24/7 insana emniyetli, saldırgana kapalı tutmak.

ANALİZ BİRİMİ
Bariyer sistemi: ürün + kurulum + süreç, tesis gözünden.

İÇ / DIŞ
İç: tesisin değiştirebildiği. Dış: kontrol edemediği.

MEVZUAT KURALI
Üreticiye yük getiren kural fırsat, tesise getiren tehdit.

	HEDEFE YARDIMCI	HEDEFE ZARARLI
İÇ · SİSTEM	**S — Güçlü yönler** (S1–S6)	**W — Zayıf yönler** (W1–W7)
DIŞ · ÇEVRE	**O — Fırsatlar** (O1–O6)	**T — Tehditler** (T1–T6)

S — Güçlü yönler

S1 **Kanıtlı fiziksel dayanım.** ISO 22343-1:2023: 7.500 kg @ 80 km/s, 1.224 kJ; Ø273 mm, 16 mm et G. Düşmanca araç zincirini (S2, R5) son halkada keser. LAB 3

S2 **Varsayılan durum güvenlik tarafında.** Bariyer normalde yukarıda V; ağ ya da YZ arızasında "kapalı kal" doğal ve ucuz bir geri dönüş. LAB 1 · 7

S3 **Çok faktörlü doğrulamaya hazır.** Loop standart; fotosel, kart okuyucu, plaka okuma ve OGS/HGS ile uyumlu G. "3 faktörden en az 2" kuralının sensörleri sahada. LAB 7

S4 **Enerjisiz kurtarma yolu.** Küresel vanayla manuel indirme (benzer modeller) G: enerji ya da kontrol sistemi çökse de bariyer güvenli duruma alınır. LAB 1 · 6

S5 **Merkezi izleme.** WOC ve Arma Mobil gerçek zamanlı rapor veriyor, bariyerleri tek merkezden yönetiyor G; doğru kurgulanırsa olay tespiti ve delil için hazır kaynak. LAB 6

S6 **Belgelenmiş Safety 4.0 tabanı.** SF haritası, zone/conduit modeli, risk register, GR-1…7, yama ve olay akışları hazır: yatırım ölçülebilir gereksinime bağlanır. LAB 1–7

W — Zayıf yönler

W1 **Emniyet ile kumanda aynı kartta.** SF-1 mantığı ağa bağlı Arma Kart'ta V; ağdan gelen her yol emniyete de dokunuyor. Projenin dijital kesişim noktası. LAB 1 · 4

W2 **Algılama boşluğu.** Loop metal kütleyi görür; yayayı hiç, bisikleti güvenilir biçimde algılamaz. Fotosel yalnız aksesuar G; SF-1 algıladığı kadar korur (GR-6). LAB 1 · 4

W3 **Kimlik ve parola hijyeni.** Paylaşılan Arma Mobil hesabı; Arma Kart, kamera ve 4G router'da varsayılan parola; Wi-Fi parolası duvarda V. En yüksek risk: S1 = 27. LAB 2 · 3

W4 **Filtresiz yollar.** Arma Kart'a dört yol: bulut/4G, 7/24 TeamViewer, kulübe Wi-Fi, sabit kodlu RF 433 MHz; üstüne kilitsiz USB; internet doğrudan Z1'de bitiyor V. LAB 2 · 4

W5 **Görünmeyen yazılım.** SBOM ve yama süreci yok V. Component X (CVSS 9.8) bugün üç şartın üçünü de sağlıyor; karar "otomatik modu durdur". LAB 5

W6 **Belgesiz yapay zekâ.** ARM.v19™ "bazı durumlarda kendileri karar veriyor" G; sitede sınır, doğruluk ya da eşik bilgisi yok, "garanti" doğrulanamıyor. LAB 7

W7 **Tanımsız olay müdahalesi.** Rol, kayıt ve delil zinciri yok V; "reset" refleksi kanıtı siler ve emniyeti doğrulanmamış bir duruma döndürür. LAB 6

O — Fırsatlar

O1 **CRA yükü tedarikçide.** CE işaretli üründe G AB kuralı: güvenli tasarım, ≥ 5 yıl destek, açık bildirimi (11.09.2026), SBOM (11.12.2027); ihlal cezası 15 M€ ya da cironun %2,5'i. Tesis bunu sözleşmeye taşır. LAB 5 · 6

O2 **Makine Yönetmeliği siberi emniyete bağlıyor.** 2023/1230 (AB, 20.01.2027): bozulmaya karşı koruma (Ek III 1.1.9), kumanda güvenilirliği (1.2.1); yeni alımda şartname dayanağı. LAB 1 · 4

O3 **Olgun standartlar, ölçülebilir kanıt.** ISO 13849-1:2023, IEC 62443-4-2, IEC TR 63069, ISO/IEC TR 5469: tedarikçiden "güvenli" sözü yerine PL, SL ve test raporu istenir. LAB 1 · 2

O4 **Hedef mimari raf ürünüyle kurulur.** Safety PLC, güvenlik sınıfı radar/tarayıcı, OT IDS, jump server, imzalı firmware ve dijital ikiz piyasada hazır; özel geliştirme gerekmez. LAB 4 · 5

O5 **YZ kuralları net, takvim uzadı.** AI Act Md. 14 (insan gözetimi) ve 15 (doğruluk, sağlamlık) belge istemeye dayanak; Ek I yüksek risk 02.08.2028'e ertelendi (2026/1744). LAB 7

O6 **Ulusal koordinasyon kanalı.** USOM, sektörel SOME'ler, 7545 sayılı Kanun ve Siber Güvenlik Başkanlığı: tehdit bilgisi, olay koordinasyonu. LAB 6

T — Tehditler

T1 **Fırsatçı ve hedefli saldırgan.** İnternete açık OT arayüzleri otomatik taranır; varsayılan parolalı PLC'ler ilk hedef (CISA AA23-335A). Hedefli: eski çalışan (S1), organize grup (S2). LAB 3

T2 **Siber-fiziksel saldırı.** RF kaydet-oynat ya da loop'a metal plakayla bariyeri indirip düşmanca araç sokmak: bariyerin var oluş nedeni olan tehdit siber yoldan da gelir. LAB 3

T3 **Tedarik zinciri ve bulut.** Bileşen açığı (Component X, 9.8) KEV'e girerse istismar hızlanır; Arma Mobil bulutunun ele geçirilmesi ya da kesintisi tesisin elinde değil. LAB 5

T4 **YZ'yi kandırmak.** Klon ya da sahte plaka, adversarial desen, tekrar oynatılan görüntü akışı → yanlış "YETKİLİ". Saldırgan modeli değil, girdiyi hedefler. LAB 7

T5 **Tesise yük getiren mevzuat.** Yaralanmada İSG (6331) ve BEKRA sorumluluğu; plaka verisinde KVKK (72 saat); 7545 ile siber olay ve zafiyetin gecikmeksizin bildirimi. LAB 6

T6 **Yaşam döngüsü ve bağımlılık.** Kapalı ekosistem (Arma Kart, WOC, Mobil, bulut); mekanik ömür yazılım desteğinden uzun olabilir (CRA tabanı 5 yıl): destek biterse yamasız kalınır. LAB 5

TOWS: SWOT'tan stratejiye

Her strateji bir iç ve bir dış faktörü eşleştirir: SO atak, WO dönüşüm, ST savunma, WT hayatta kalma stratejisidir. Kodlar sonraki sayfadaki yol haritasına bağlanır; etiketler sorumluyu (Tesis · Entegratör · Arma) ve evreyi gösterir.

İÇ → / DIŞ ↓

S · Güçlü yönler

S1 fiziksel dayanım · S2 varsayılan kapalı · S3 entegrasyon · S4 manuel indirme · S5 izleme · S6 belgeler

W · Zayıf yönler

W1 aynı kart · W2 algılama · W3 hijyen · W4 filtresiz yol · W5 SBOM yok · W6 belgesiz YZ · W7 olay müdahalesi

O · Fırsatlar

O1 CRA
O2 MR 2023/1230
O3 standartlar
O4 raf ürünler
O5 AI Act
O6 ulusal kanal

SO · Güçle fırsatı kullan

SO1 · Çok faktörlü geçiş — S3 + O3 · O5

Kart, plaka ve loop'tan en az ikisi uyuşmadan "aç talebi" yok; ARM.v19™ yalnız öneri verir, belirsiz durumda görevli karar verir.

Tesis + entegratör · 1–6 ay · LAB 7

SO2 · Kayıttan delile — S5 + O6

WOC ve Mobil kayıtları Z4'teki merkezi kayda ve OT IDS'e akar; USOM/SOME bildirim şablonu hazır tutulur.

Tesis · 1–6 ay · LAB 6

SO3 · Sözleşmeyle güvenlik — S6 + O1 · O2

GR-1…7 satın alma ve bakım sözleşmesine yazılır: SBOM, imzalı firmware, açık bildirimi, yazılı destek süresi, IEC 62443-4-2 kanıtı.

Tesis → Arma · 6–18 ay · LAB 4 · 5

WO · Fırsatla zayıflığı kapat

WO1 · Emniyeti ayır — W1 + O2 · O4

SF-1 ağsız Z0'daki Safety PLC'ye taşınır (PLr e); Arma Kart yalnız "yükseltme talebi" gönderir: izin = talep ∧ ¬varlık. Arma'yla yapılır, çünkü MR 2023/1230'da esaslı değişikliği yapan imalatçı sayılır.

Entegratör + Arma · 1–6 ay · GR-1 · 2 · 4

WO2 · Yayayı gör — W2 + O4

Güvenlik sınıfı radar ya da tarayıcı bariyerin tüm hareket hacmini izler; yaya geçidi araç şeridinden ayrılır (E↓).

Tesis + entegratör · 1–6 ay · GR-6 · LAB 3

WO3 · Yazılımı görünür kıl — W5 + O1

Arma'dan CycloneDX/SPDX SBOM; CVE ve KEV izlemesi; dijital ikizde test edilmiş planlı yama (Pazar 02:00–04:00).

Arma + tesis · 6–18 ay · LAB 5

WO4 · YZ'ye sınır çiz — W6 + O5 · O3

Eşikler: < 0,80 kapalı kal · 0,80–0,95 insana sor · ≥ 0,95 ve ikinci faktör → talep; yanlış kabul < 1/10.000; tedarikçiden doğruluk ve sağlamlık raporu.

Arma + tesis · 6–18 ay · LAB 7

T · Tehditler

T1 saldırgan
T2 siber-fiziksel
T3 tedarik zinciri
T4 YZ'yi kandırma
T5 tesis mevzuatı
T6 yaşam döngüsü

ST · Güçle tehdidi karşıla

ST1 · Şüphede kapalı kal — S1 + S2 ↔ T2 · T4

Girdiler çelişirse ya da görüntü kalitesi düşerse bariyer yukarıda kalır ve alarm üretir; sas kilidi: iç ve dış hat aynı anda inmez.

Tesis · 0–30 gün · LAB 3 · 7

ST2 · Ağsız işletme modu — S4 ↔ T1 · T3

Siber olayda otomatik mod durur, görevli manuel basılı-tut modda işletir. Küresel vana panosu kilitlenir ve mühürlenir: fiziksel erişim de bir saldırı yolu.

Tesis · 0–30 gün · LAB 5 · 6

ST3 · Kanıt dosyası — S6 ↔ T5

Risk değerlendirmesi, SF doğrulama, değişiklik ve olay kayıtları tek dosyada tutulur: İSG, BEKRA ve KVKK denetiminde savunma.

Tesis · 1–6 ay · LAB 1 · 6

WT · Zayıflığı azalt, tehditten kaç

WT1 · Acil hijyen — W3 · W4 ↔ T1

Paylaşılan hesap kapanır (kişisel hesap + MFA), varsayılan parolalar değişir, TeamViewer kalkar, USB kilitlenir, 4G port yönlendirmesi kapanır.

Tesis · 0–30 gün · LAB 2 · 3 · 4

WT2 · Tek kapı — W4 ↔ T1 · T3

İnternetin Z1'e yolu kesilir; uzak erişim yalnız Z4 jump server'dan: VPN + MFA, onaylı 2 saatlik pencere, tam kayıt. Bulut yalnız giden bağlantı kurar.

Tesis + entegratör · 1–6 ay · LAB 4

WT3 · RF'yi emekliye ayır — W4 ↔ T2

Sabit kodlu 433 MHz yerine kayan kodlu ya da şifreli alıcı; RF yalnız "aç talebi" taşır, görevli onaylar.

Tesis · 1–6 ay · LAB 3

WT4 · YZ emniyetin dışında — W6 ↔ T4

YZ talep eder, karar vermez: manipülasyonun etkisi sınırlanır, ARM.v19™ da MR 2023/1230 Ek I Bölüm A'daki "emniyet işlevi gören öğrenen bileşen" sınıfına girmez (AI Act ayrıca incelenir).

Tesis + Arma · tasarım kararı · LAB 7

WT5 · Önce kanıt, sonra reset — W7 ↔ T1 · T5

Olay rol tablosu, 15 dk ve 2 saat adımları, kayıt ve delil zinciri; yılda en az bir tatbikat.

Tesis · 0–30 gün · LAB 6

Uygulama yol haritası

Önce maliyetsiz ve geri alınabilir adımlar, sonra mimari, en son yönetişim; her evre ölçülebilir bir ölçütle kapanır.

0–30 gün

Hızlı kazanım · prosedür ve yapılandırma

- **WT1** Acil hijyen
- **WT5** Önce kanıt, sonra reset
- **ST1** Şüphede kapalı kal
- **ST2** Ağsız işletme modu
- **WT4** YZ emniyetin dışında (tasarım kararı)
- **LAB 5** Component X: otomatik mod durur, yama ≤ 72 saat

BAŞARI ÖLÇÜTÜ

- [ ] Paylaşılan hesap = 0
- [ ] Varsayılan parola = 0
- [ ] İnternetten Z1'e açık port = 0
- [ ] Olay planı onaylı, ilk tatbikat yapıldı

1–6 ay

Mimari · yatırım

- **WO1** Emniyeti ayır
- **WO2** Yayayı gör
- **WT2** Tek kapı
- **WT3** RF'yi emekliye ayır
- **SO1** Çok faktörlü geçiş
- **SO2** Kayıttan delile
- **ST3** Kanıt dosyası

BAŞARI ÖLÇÜTÜ

- [ ] SF-1 Z0'da, PLr e doğrulandı (GR-4)
- [ ] Alan doluyken hiçbir kaynaktan gelen komut hareket ettirmiyor (GR-2 testi)
- [ ] Uzak oturumların %100'ü kayıtlı
- [ ] S1: 27 → 9

6–18 ay

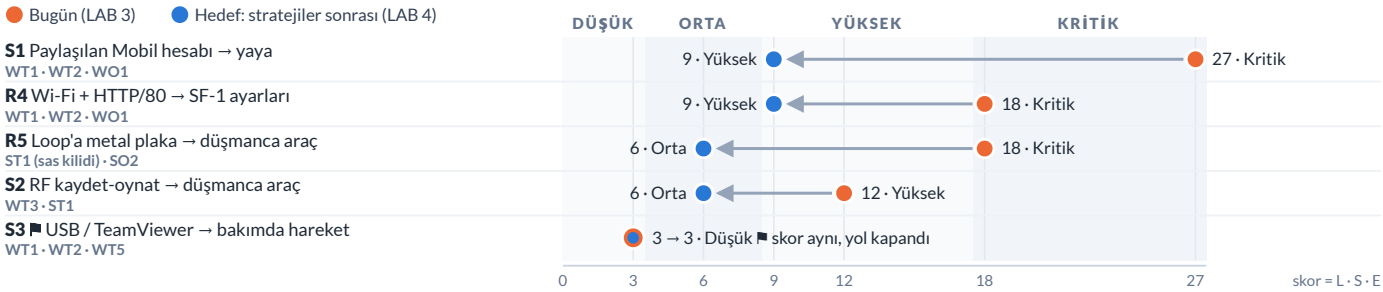
Yönetişim · sözleşme

- **SO3** Sözleşmeyle güvenlik
- **WO3** Yazılımı görünür kıl
- **WO4** YZ'ye sınır çiz
- ↻ Yılda bir: SWOT ve risk register yeniden gözden geçirilir

BAŞARI ÖLÇÜTÜ

- [ ] SBOM teslim alındı, aylık CVE/KEV taraması
- [ ] Kritik açıkta karar ≤ 72 saat
- [ ] YZ yanlış kabul < 1/10.000, aylık izleniyor
- [ ] Destek süresi sözleşmede yazılı

Stratejilerin risk etkisi



> Kalan skorların hepsi S = 3'ten gelir: siber önlemler olasılığı (L) düşürür, şiddeti asla. Şiddeti yalnız fiziksel tasarım sınırlar: SF-1'in bağımsızlığı, sas kilidi, yayanın şeritten ayrılması. S3'ün skoru değişmez; bayrak ancak emniyet testleri geçince kalkar.

Dış takvim: fırsat ve tehditler ne zaman devreye giriyor?

BUGÜN · 20.10.2026

19.03.2025
YÜRÜRLÜKTE
7545 sayılı Kanun: siber olay ve zafiyet Başkanlığa gecikmeksizin bildirilir.
T5 → WT5 · ST3

11.09.2026
YÜRÜRLÜKTE
CRA Md. 14: üretici aktif istismar edilen açığı 24 s içinde bildirir.
O1 → SO3

09.12.2026
AKTARIM TARİHİ
Ürün Sorumluluğu Direktifi: eksik güvenlik güncellemesi kusur sayılabilir.
O1 → SO3

20.01.2027
UYGULAMA
Makine Yönetmeliği 2023/1230: bozulmaya karşı koruma zorunlu.
O2 → WO1 · SO3

11.12.2027
UYGULAMA
CRA'nın tamamı: Ek I gereksinimleri, açık yönetimi, SBOM.
O1 → WO3 hazır

02.08.2028
UYGULAMA
AI Act Ek I yüksek risk yükümlülükleri (2026/1744 ile ertelendi).
O5 → WO4 hazır

Fırsat (O) · Tehdit (T) · ○ Boş daire: henüz başlamadı

Sonuç

Bu sistemin en büyük gücü fiziksel (çarpışma dayanımı, S1), en büyük zayıflığı dijital (emniyetle kumandanın aynı kartta olması, W1). Bariyeri indiren her yol bir güvenlik açığı, yükselten her yol bir emniyet tehlikesi olduğundan en yüksek getirili strateji bir yazılım ayarı değil, mimaridir: **SF-1'i ağdan ve YZ'den bağımsız bir katmana almak (WO1)**. CRA, Makine Yönetmeliği ve AI Act tesis için tedarikçiden kanıt istemenin kaldıracıdır (SO3). İlk 30 günün neredeyse maliyetsiz adımları en yüksek riskin (S1 = 27) giriş kapısı olan paylaşılan hesabı kapatır.

Kaynaklar: CRA (AB) 2024/2847 Md. 13(8), 14, 64 · Makine Yönetmeliği (AB) 2023/1230 · Yapay Zekâ Yasası (AB) 2024/1689, (AB) 2026/1744 ile değişik · Ürün Sorumluluğu Direktifi (AB) 2024/2853 · 7545 sayılı Siber Güvenlik Kanunu (RG 19.03.2025) · 6331 sayılı İSG Kanunu · BEKRA Yönetmeliği · 6698 sayılı KVKK · CISA AA23-335A · ISO 22343-1:2023 · ISO 13849-1:2023 · IEC 62443-4-2 · IEC TR 63069 · ISO/IEC TR 5469:2024 · ürün verileri: armakontrol.com. **Sınır:** Zayıf yönlerin çoğu eğitim senaryosu varsayımıdır [V]; gerçek bir kurulumda saha incelemesiyle doğrulanmalıdır.